

LIVRABLE 2 : CHARTE GLOBALE DE POLITIQUE DE GOUVERNANCE DES DONNÉES

Auteur : Caroline HEYMES

Date : 9 juin 2026

Cas d'étude : Spotify S.A.

TABLE DES MATIÈRES

1. Objet de la charte et cadre de référence	Page 1
2. Les neuf principes fondamentaux de la gouvernance de Spotify	Page 1
3. Modèle de gouvernance et organisation des pouvoirs (rôles et responsabilités)	Page 2
4. Cadre de conformité légale (RGPD, CCPA, PCI-DSS)	Page 3
5. Accessibilité numérique et inclusion des personnes (RGAA et WCAG)	Page 4
6. Veille réglementaire continue et procédures de mise à jour	Page 4
7. Conclusion	Page 4

1. OBJET DE LA CHARTE ET CADRE DE RÉFÉRENCE

Cette charte définit le cadre réglementaire, organisationnel et technique applicable à l'ensemble des actifs de données de Spotify Technology S.A. dans ses 180 pays d'opération.

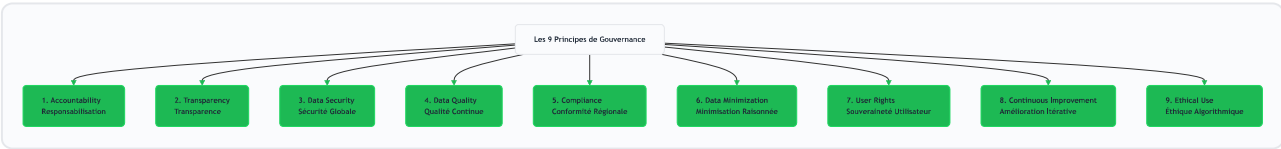
Fondements théoriques

Cette politique s'appuie sur deux référentiels d'autorité en matière de gestion des données et de sécurité de l'information :

- Le cadre méthodologique **DAMA-DMBOK2** (*Data Management Body of Knowledge*) pour structurer les domaines de connaissances de la gestion de données.
- La norme **ISO/IEC 27001:2022** pour la mise en œuvre du Système de Management de la Sécurité de l'Information (SMSI).

2. LES NEUF PRINCIPES FONDAMENTAUX DE LA GOUVERNANCE

Pour guider l'action des équipes et concilier l'innovation technologique avec la protection des utilisateurs, Spotify retient une structure de neuf principes directeurs :

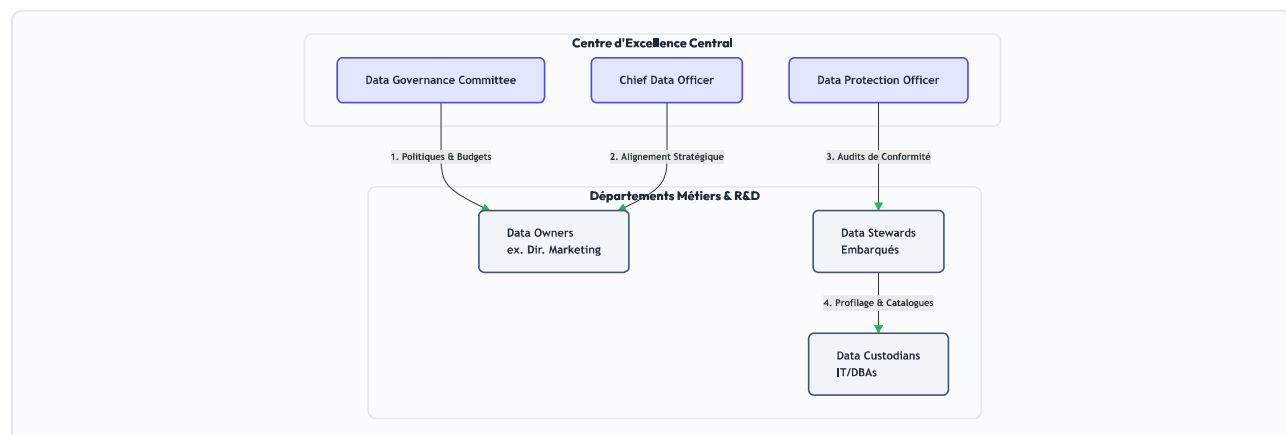


Les applications opérationnelles des principes directeurs de Spotify sont structurées comme suit :

1. Responsabilisation Chaque donnée collectée ou traitée est rattachée à un propriétaire identifié (<i>Data Owner</i>) et supervisée par un gestionnaire (<i>Data Steward</i>).	2. Transparence Spotify explique de manière claire comment les données d'écoute, de recherche et de profil sont exploitées par nos modèles d'IA.	3. Sécurité Globale Données protégées par un chiffrement fort (AES-256 au repos, TLS 1.3 en transit) et cloisonnement des bases financières PCI-DSS.
4. Qualité Continue Audits et règles de nettoyage automatique des métadonnées du catalogue en ligne exécutés en temps réel lors de l'ingestion.	5. Conformité Régionale Alignement rigoureux sur les législations territoriales les plus protectrices (RGPD en Europe, CCPA aux USA, PDPA à Singapour).	6. Minimisation Collecter uniquement les données nécessaires au streaming et purger automatiquement les logs bruts après 24 mois d'inactivité.
7. Souveraineté Chaque abonné dispose d'un contrôle automatisé direct sur ses droits légaux (accès, oubli) depuis l'interface de l'application.	8. Progrès Itératif Évaluation bimensuelle et adaptation continue du cadre réglementaire face aux évolutions de l'IA et de la législation.	9. Éthique IA Surveillance continue des réseaux de neurones pour détecter et corriger les biais d'exclusion d'artistes ou stéréotypes musicaux.

3. MODÈLE DE GOUVERNANCE ET ORGANISATION DES POUVOIRS

Pour éviter les conflits d'intérêts où les équipes techniques évaluent leurs propres réalisations, Spotify retient une structure de gouvernance fédérée asynchrone. Ce modèle est piloté par un Centre d'Excellence (CoE) indépendant de la direction informatique (DSI).



Rôles stratégiques (Centre d'Excellence - CoE)

Chief Data Officer (CDO) COE Mission : Diriger la stratégie de valorisation de la donnée et présider le comité. - Allouer les budgets technologiques. - Arbitrer les écarts sémantiques. - Évaluer la valeur économique des actifs.	Data Protection Officer (DPO) COE Mission : Garantir la conformité légale et la protection de la vie privée mondiale. - Mener les analyses d'impact (AIPD). - Assurer la liaison réglementaire CNIL. - Coordonner les violations de données.	Comité de Gouvernance COE Mission : Valider les politiques globales et piloter l'évaluation de la maturité data. Membres : CDO, DPO, DSI, Directeurs du Marketing, R&D et Finance.
---	--	---

Rôles opérationnels (Métiers & R&D)

Data Owner (Propriétaire)

MÉTIER

Mission : Garantir la définition, la qualité et la conformité éthique de son domaine métier.

- Déclarer la propriété technique via un fichier `owner.yaml` dans Git.
- Gérer l'élimination des ressources orphelines via **Backstage**.

Data Steward (Gestionnaire)

MÉTIER

Mission : Traduire les politiques centrales en configurations dans les Squads.

- Documenter les jeux de données (écoute/profils).
- Valider et exécuter les règles de qualité.
- Comparer les pipelines aux **Golden States**.

Data Custodian (Gardien)

MÉTIER

Mission : Opérer l'infrastructure cloud physique de stockage (Data Engineers, SREs).

- Administrer GCP (BigQuery, Cloud Storage).
- Appliquer le chiffrement KMS sélectif.
- Automatiser le cycle de vie par script.

4. CADRE DE CONFORMITÉ LÉGALE (RGPD, CCPA, PCI-DSS)

La conformité chez Spotify est conçue comme un processus automatisé, intégré directement dans nos pipelines d'ingestion et de traitement des données.

4.1. Principes de traitement du RGPD (Article 5)

Légalité (Lawfulness)

Chaque traitement s'appuie sur une base légale définie : contrat (streaming), consentement (pub), intérêt légitime (lutte anti-fraude).

Loyauté (Fairness)

L'algorithme ne doit jamais manipuler ou biaiser le comportement d'écoute de l'utilisateur de manière trompeuse.

Transparence (Transparency)

L'architecture de nos algorithmes de recommandation est rigoureusement documentée pour assurer l'explicabilité de l'IA.

4.2. Automatisation des droits des abonnés

Droit d'accès & portabilité

Un clic sur l'application déclenche la compilation automatique de l'historique d'écoute par API dans un fichier JSON, disponible au téléchargement sous 48h.

Droit à l'oubli (effacement)

La résiliation déclenche un signal API programmé purgeant ou anonymisant de manière irréversible toutes les données de l'utilisateur sous 30 jours.

4.3. Protocole de notification des violations de données (Incident Cyber)

1

Détection continue

Surveillance active des accès bases de données en temps réel via Splunk SIEM.

2

Confinement immédiat

Isolation immédiate de l'environnement compromis par l'équipe SecOps.

3

Évaluation & Alerte

Le DPO évalue le risque, notifie la CNIL sous 72h et alerte les abonnés si nécessaire.

4.4. Chiffrement KMS & cycle de vie automatique

Chiffrement KMS sélectif

Cryptage sélectif au repos (AES-256) des informations sensibles (PII, facturation) avec cloisonnement strict et rotation continue des clés KMS cloud, limitant l'accès selon le principe du moindre privilège.

Cycle de vie codé

Les règles de rétention et les politiques de purge (destruction automatique après 24 mois d'inactivité) sont codées sous forme de règles logicielles d'infrastructure sans intervention humaine.

5. ACCESSIBILITÉ NUMÉRIQUE ET INCLUSION (RGAA ET WCAG)

[IMPORTANT] L'inclusion et l'accessibilité des personnes en situation de handicap représentent une exigence réglementaire et professionnelle fondamentale de notre démarche d'architecture.

Spotify intègre les exigences du **RGAA 4.1.2** et les normes internationales **WCAG 2.2** :

5.1. Plateformes internes de données

Les portails, catalogues (Collibra, Alation) et Dashboards (Tableau, Looker) respectent les normes d'accessibilité :

- Lecteurs d'écran (HTML5 sémantique, ARIA).
- Navigation clavier exclusive par Tabulation.
- Rapport de contraste minimal (4.5:1 / 3:1).

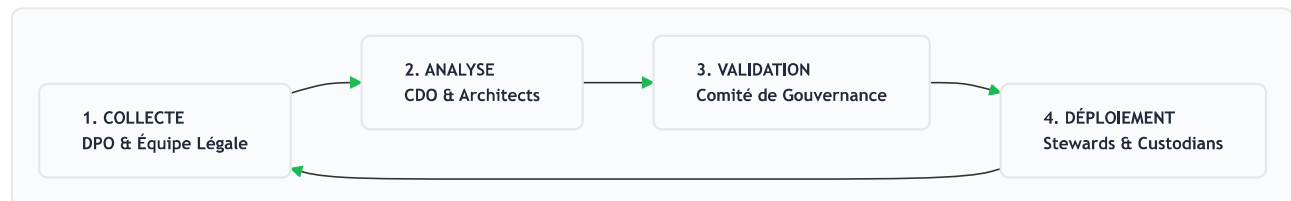
5.2. Application cliente externe

L'application grand public intègre également des technologies inclusives :

- Contrôle vocal étendu pour handicap moteur.
- Transcriptions textuelles synchronisées en temps réel des flux audio et des podcasts.

6. VEILLE RÉGLEMENTAIRE CONTINUE ET MISE À JOUR

Pour adapter notre cadre à l'**EU AI Act**, un processus de veille bimensuelle est exécuté :



7. CONCLUSION

Cette charte de gouvernance dote Spotify d'un cadre de responsabilité solide. En articulant nos processus autour d'un CoE indépendant, en automatisant la conformité (RGPD) et en appliquant l'inclusion par conception (RGAA/WCAG), Spotify sécurise son business tout en créant un environnement IA d'excellence, sûr et éthique.